

웹 공격 문자열을 이미지로 바꿔 탐지하는 2단 구조 연구

텍스트 모델로 입력 필드 실험을 마무리하고, 실사용자 정상 요청의 오탐률을 처음 실측한 결과

보고일 2026-09-15 · 보고 범위 2026-09-14 ~ 2026-09-15 (직전 보고 이후분)

세 줄 요약

- 입력 필드 실험 완료** — 지난 보고에서 미실행이던 **텍스트 모델(문자 단위 CNN)**을 같은 조건으로 돌렸습니다. 텍스트 모델은 조합 간 차이가 0.3%p 이내라 규칙상 "URI+본문"을 골랐고, 미리 정한 규칙(두 모델이 같으면 이미지 모델을 따름)대로 **학습 데이터 입력은 "URI+본문+쿠키"로 확정**합니다. 텍스트 모델도 이 입력에서 손해 없습니다.
- 실사용자 정상 요청의 오탐률을 처음 실측했습니다** — **실사용자 2.73% vs 스캐너 0.36%(약 8배)**. 지난 보고의 한계("정상 = 스캐너 탐색 요청 위주")가 수치로 확인됐고, 오탐률은 반드시 출처별로 나눠 보고하겠습니다.
- 평가 지표 정비** — 선행연구 대조에서 나온 권고(교정 지표·유병률 병기·효율 점수·신뢰구간)를 반영하고, 회피 실험 지표를 문헌 용어(ASR-AUA)에 맞췄습니다. 지난 보고의 수치 하나(실사용자 요청 수)도 정정합니다.

0. 읽기 전에 — 이 보고서에 나오는 용어

용어	뜻 (예시)
2단 구조	빠른 이미지 모델 이 모든 요청을 먼저 보고, 확신이 낮은 소수만 느리지만 정확한 텍스트 모델 에 넘기는 구성. 본 연구가 제안하는 모델입니다.
입력 필드	HTTP 요청에서 모델에 넣는 부분. 예: GET /login.php?id=1' OR '1'='1 의 주소(URI), 폼으로 보낸 본문, 브라우저가 붙이는 쿠키·User-Agent(브라우저 이름표).
Macro-F1	4개 클래스(정상·SQL 주입·코드 주입·명령 주입) 각각의 정확도 점수(F1)를 단순 평균 한 값. 1.0 이 만점. 건수가 적은 명령 주입을 못 맞히면 크게 깎입니다.
오탐 / 오탐률	정상 요청을 공격으로 잘못 막는 것. 오탐률 1% = 정상 요청 100건 중 1건을 막음.
오탐 1%일 때 탐지율	"정상 100건 중 1건까지만 잘못 막도록 기준을 조였을 때 공격을 몇 % 잡는가". 실제 운영에 가까운 지표입니다.
5겹 교차검증	데이터를 5등분해 4조각으로 학습하고 1조각으로 채점하기를 5번 돌려 평균. 한 번만 재면 운에 따라 흔들리는 것을 막습니다.
시험 데이터 봉인	최종 채점용 데이터(15%)는 입력 고르기에 한 번도 쓰지 않음 . 고르는 데 쓰면 나중 성적이 부풀려집니다(문제 보고 시험 치기와 같음).
보정 p (Holm)	"두 조합의 차이가 우연일 확률"을 여러 번 비교한 만큼 엄격하게 고친 값. 0.05 보다 작으면 진짜 차이 로 봅니다.
95% 신뢰구간 [a, b]	표본이 작아 생기는 불확실성의 폭. "진짜 값은 대략 a~b 사이". 건수가 적을수록 넓어집니다.
지름길(shortcut)	모델이 공격 내용 이 아니라 우연히 따라붙은 흔적(예: 공격 도구가 늘 쓰는 쿠키)으로 맞는 것. 실제 환경에서는 통하지 않습니다.

1. 지난 보고 정정

지난 보고 6절에서 "실사용자 브라우저에서 온 정상 요청은 **고유 3,666개**"라고 썼는데, 이 숫자는 **라벨 오류 감사로 걸러낸 요청(실제 공격 30,280건)**을 빼기 전에 센 값이었습니다. 학습 데이터 기준으로 다시 세면 아래와 같습니다.

정상 요청의 출처 (중복 제거 후)	학습	검증	시험	계
실사용자 브라우저로만 온 요청	439	111	95	645 (1.0%)
실사용자·스캐너 양쪽에서 온 요청	1,463	293	297	2,053
스캐너로만 온 요청	44,962	9,638	9,650	64,250

스캐너 판정 기준: 공격 요청에서 가장 흔한 User-Agent 1개(데이터에서 계산). 한 번이라도 실사용자로 온 요청은 $645 + 2,053 = 2,698$ 개 (4.0%).

결론 방향은 같고 오히려 더 강해졌습니다. 다만 **시험 데이터의 실사용자 요청은 95개뿐**이라, 오탐이 0건이어도 95% 신뢰구간 상한이 약 3.9%입니다. 이 해상도로는 "실사용자에게 오탐이 낮다"는 주장을 할 수 없습니다.

쉽게 말하면 정상 요청 약 6.7만 개 가운데 "진짜 사람이 브라우저로 보낸 요청"은 100개 중 1개꼴입니다. 나머지는 공격 도구(스캐너)가 사이트를 훑으며 보낸 평범한 요청이라, 모델은 사실상 "스캐너의 공격 vs 스캐너의 탐색"을 구분하는 법을 배웁니다.

2. 입력 필드 실험 — 텍스트 모델 결과

지난 보고와 **똑같은 분할**(시험 데이터 봉인, 학습+검증 226,048건, 5겹 교차검증)과 똑같은 채택 규칙을 적용했습니다. 두 모델이 같은 분할을 공유하므로 모델 간 비교도 대응표본으로 성립합니다. GPU 약 3시간.

입력	Macro-F1 (평균±표준편차)	오탐 1%일 때 탐지율	명령 주입 F1	정상 F1
URI	0.884 ± 0.003	0.989	0.586	0.982
URI + 본문	0.990 ± 0.003	0.997	0.974	0.992
URI + 본문 + 쿠키	0.991 ± 0.004	0.998	0.977	0.993
URI + 본문 + 쿠키 + User-Agent	0.993 ± 0.002	0.9985	0.984	0.994
대조군: User-Agent + 쿠키만	0.542 ± 0.048	0.113	0.192	0.676

문자 단위 CNN, 입력 길이 2,304바이트. 유의성은 대응표본 t-검정 + Holm 보정(대조군 제외 4조합 6쌍).

- **URI만 쓰면 확실히 나뉩니다**(나머지 세 조합 모두 보정 $p < 0.0001$).
- **본문 이후로 필드를 더해도 구분이 안 됩니다** — 세 조합 간 보정 $p = 0.34 \sim 0.45$. 규칙("유의차가 없으면 필드가 적은 쪽")에 따라 텍스트 모델의 채택은 **URI + 본문**입니다.
- **최종 입력은 "URI + 본문 + 쿠키" 유지**. 두 모델의 선택이 같으면 2단 구조의 1차인 이미지 모델을 따르기로 실험 전에 정해 두었습니다. 텍스트 모델도 이 입력에서 URI+본문보다 0.1%p 높아 손해가 없습니다.

쉽게 말하면 텍스트 모델에게는 주소와 본문만 있으면 충분하고, 쿠키·User-Agent 를 더 줘도 점수가 사실상 그대로입니다($0.990 \rightarrow 0.993$, 통계적으로 구분 불가). 반면 주소만 주면 명령 주입 구분이 크게 무너집니다(명령 주입 F1 0.586) — 본문을 빼면 명령 주입을 가르는 단서가 많이 사라진다는 뜻입니다. 대조군(쿠키·User-Agent 만)이 0.54 에 그친 것은 "이 두 필드만으로는 공격을 가할 수 없다"는 뜻입니다.

2.1 두 모델을 나란히 놓고 보이는 것

입력	이미지 CNN Macro-F1	텍스트 CNN Macro-F1	이미지 CNN 오탐1% 탐지율	텍스트 CNN 오탐1% 탐 지율
URI	0.844	0.884	0.876	0.989
URI + 본문	0.895	0.990	0.867	0.997
URI + 본문 + 쿠키 (채택)	0.932	0.991	0.850	0.998
URI + 본문 + 쿠키 + User-Agent	0.923	0.993	0.831	0.9985

이미지 CNN 수치는 지난 보고(2026-09-14)와 같은 결과 파일.

쉽게 말하면 예를 들어 쿠키를 추가했을 때 이미지 모델은 0.895 → 0.932 로 뚜렷이 좋아졌지만, 같은 입력을 받은 텍스트 모델은 0.990 → 0.991 로 거의 그대로입니다. 같은 정보를 줬는데 한쪽만 좋아졌다면, 쿠키 안의 **공격 내용**이 아니라 "쿠키가 붙어 있다/길다" 같은 **겉모양**을 이미지 모델이 이용했을 가능성이 있습니다. 이것이 아래에서 "쿠키를 비운 입력"으로 확인하려는 이유입니다.

해석할 때 주의할 점

- 쿠키를 넣었을 때 좋아지는 건 **이미지 모델뿐입니다**(+3.7%p, 유의 / 텍스트 모델 +0.1%p, 구분 안 됨). 지난 보고에서 "쿠키의 내용이 아니라 쿠키가 있는가가 신호일 수 있다"고 말씀드린 의심이 더 커졌습니다. **쿠키를 비운 입력으로 확인하는 실험을 다음 순서의 맨 앞에** 두겠습니다.
- 지난 보고의 "필드를 더할수록 오탐 1% 탐지율이 떨어진다"는 **이미지 모델에만 해당**합니다. 텍스트 모델은 반대로 올라갑니다.
- 이 실험에서는 텍스트 모델이 모든 입력에서 크게 앞섭니다. 첫 번째 연구 질문의 기존 결론("이미지 단독은 텍스트 모델에 열세")과 방향은 같지만, 이 실험은 **입력을 고르기 위한 것**이라 그 질문의 판정에는 쓰지 않습니다. 판정은 입력 전환 후 시험 데이터로 1회 측정합니다.

3. 정상 요청의 출처별 오탐률 (첫 실측)

이번 실행부터 교차검증 결과에 **정상 요청의 출처별 오탐률**이 함께 기록됩니다. 실사용자 요청은 한 겹에 약 110개뿐이라, 다섯 겹의 건수를 합쳐 신뢰구간(Wilson 95%)을 냈습니다.

입력 (텍스트 CNN)	실사용자 (550건)	양쪽 출처 (1,756건)	스캐너 (54,600건)	전체 (56,906건)
URI	24.9% [21.5, 28.7]	0.97%	2.44%	2.61%
URI + 본문	2.73% [1.66, 4.45]	0.00%	0.36% [0.32, 0.42]	0.37%
URI + 본문 + 쿠키	2.91% [1.80, 4.67]	0.11%	0.27% [0.23, 0.32]	0.29%
URI + 본문 + 쿠키 + User-Agent	2.00% [1.12, 3.55]	0.11%	0.25% [0.21, 0.29]	0.26%

[] 는 95% Wilson 신뢰구간. 오탐 = 정상 요청을 공격 클래스로 판정.

쉽게 말하면 "URI + 본문" 기준으로, 스캐너가 보낸 정상 요청은 **1,000건 중 약 4건**만 잘못 막지만 진짜 사람이 보낸 정상 요청은 **1,000건 중 약 27건**을 잘못 막습니다. 모델이 주로 스캐너 요청으로 "정상"을 배웠기 때문에, 처음 보는 사람의 요청을 더 자주 의심하는 것으로 해석됩니다. 전체 평균(0.37%)만 보면 이 차이가 가려집니다. 주소만 쓰는 입력(24.9%)은 사람 요청의 4건 중 1건을 막아 쓸 수 없는 수준입니다.

실사용자 요청의 오탐률이 스캐너 요청의 약 8~11배이고 신뢰구간도 겹치지 않습니다. 전체 오탐률 0.3%대는 정상 요청의 96%를 차지하는 스캐너 탐색 요청이 만든 숫자입니다. 논문에서는 **전체 오탐률을 "실운영 오경보율"로 쓰지 않고, 실사용자 총 수치를 반드시 함께 실겠습니다.** (이미지 모델은 이 기록 기능을 넣기 전에 실행해 출처별 수치가 없습니다. 본 측정에서 함께 냅니다.)

4. 평가 지표 정비

선행연구 대조에서 나온 지표 권고를 GPU 재측정 **전에** 반영했습니다(지표가 빠진 채 돌리면 학습을 다시 해야 하므로).

추가·변경	이유
Brier 점수 (교정 지표)	기존 교정 오차(ECE)는 구간 나누기에 값이 좌우됩니다. 교정을 보고하는 인접 연구 2편이 모두 Brier를 씁니다.
PR-AUC 에 유병률 병기	PR-AUC는 공격 비율에 직접 의존합니다. 시험 데이터의 공격 비율(74.8%)을 함께 적고, 드문 쪽인 정상을 양성으로 본 값도 냅니다.
효율 점수(FE)	2단 구조와 가장 가까운 선행연구(Tasdemir 2023)가 실제로 쓰는 지표라 비교에 필요합니다.
부트스트랩·Wilson 신뢰구간	표본이 작은 평가(실사용자 총, 라벨 오류 공격 세트)에서 구간을 함께 보고하기 위해서입니다.
회피 실험: ASR 명확화 + AUA-AMB 신설	문헌의 공격 성공률(ASR)은 "공격이 정상으로 통과한 비율"입니다. 기존 결과에서 ASR은 전 구간 0이었지만, 공격 하 정확도(AUA)는 0.997 → 0.658로 떨어졌습니다. 둘을 함께 실어야 "탐지 우회에는 강하지만 공격 종류 판정은 무너진다"가 드러납니다. AMB는 회피에 성공하는 데 필요한 최소 변형 수(공격자 비용)입니다.

쉽게 말하면 공격 문자열을 조금씩 바꿔(예: or → oR, 공백 → 주식) 모델을 속여 보는 실험에서, **ASR** 은 "바뀐 공격이 정상으로 통과한 비율", **AUA** 는 "바뀐 공격의 종류까지 맞힌 비율"입니다. 기존 결과는 통과는 한 건도 없었지만(ASR 0) 종류 판정은 99.7% → 65.8% 로 무너졌습니다 — 막기는 막는데 "무슨 공격인지"는 헛갈린다는 뜻입니다. ASR 만 보고 하면 "아무 문제 없음"으로 읽히므로 두 값을 함께 실습니다.

5. 기타 준비 작업

- "방화벽 규칙을 통과한 실제 공격" 평가 세트 구성 — 라벨 오류 감사로 걸러낸 30,280건을 평가용으로 정리했습니다. 이 중 760건은 학습 데이터의 SQL 주입 요청과 문자열이 완전히 같았습니다(같은 공격이 원본에 한 번은 정상, 한 번은 SQL 주입으로 기록). 라벨 오류라는 독립 방증이지만 모델이 학습 때 이미 본 문자열이므로, 탐지율 헤드라인은 겹치지 않는 요청으로만 내고 겹친 760건은 따로 적기로 측정 전에 정했습니다.
- 2단 구조 판정 신호 비교 도구 — 1차 모델이 2차로 넘길지 정하는 신호(최대 확률, 온도 보정 확률, 1·2위 차, 엔트로피)를 비교하는 도구를 먼저 만들었습니다. 측정은 입력 전환 후입니다.
- 데이터셋 원 논문 2편 확보 — 주 데이터셋 논문(2022)과 외부 검증 데이터셋 논문(2025) 원문을 받아 대조하다가, 참고문헌 목록에 적어 둔 저자명 오류(실존하지 않는 저자)를 발견해 고쳤습니다.

6. 다음 계획

1. 학습 데이터 입력을 "URI + 본문 + 쿠키"로 전환하고, 쿠키를 비운 입력으로 이미지 모델의 쿠키 이득이 지름길인지 확인
2. 입력 전환 후 전 모델(이미지·텍스트·2단 구조)을 시험 데이터로 본 측정 — 출처별 오탐률 포함
3. 2단 구조 판정 신호 비교, "방화벽 규칙을 통과한 실제 공격" 세트 탐지율 측정

7. 여쭙고 싶은 것

Q1 실사용자 오탐률을 무엇으로 보고할까요?

시험 데이터의 실사용자 요청은 95개뿐이라 신뢰구간이 넓습니다. (가) 시험 데이터 값을 주 수치로 쓰고 구간과 한계를 명시한다 / (나) 교차검증 5겹 합산(550건)을 주 수치로 쓰고 시험 데이터 값을 병기한다. (나)가 해상도는 높지만 입력 선택에도 쓰인 데이터라, 저희는 (가)를 기본으로 두고 (나)를 보조로 실는 안을 생각하고 있습니다.

Q2 쿠키 확인 실험에서 지름길로 나오면

쿠키를 비웠을 때 이미지 모델 성능이 "URI + 본문" 수준으로 떨어지면, 쿠키 이득은 내용이 아니라 존재 여부 신호로 봐야 합니다. 그 경우 입력을 "URI + 본문"으로 되돌리는 것(사전 규칙의 예외)과, 채택은 유지하고 한계로만 적는 것 중 어느 쪽이 적절할지 의견을 여쭙고 싶습니다.